PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Gestion des données et traitements sensibles

03-230 ANSSI - Données et traitements sensibles — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'échelle d'impact doit être un outil homogène défini pour toute l'entité afin d'évaluer les conséquences d'une compromission.
2. La sensibilité des données se décline en 3 niveaux selon la gravité de l'impact : non sensible, sensible ou très sensible.
3. L'évaluation doit privilégier une approche par catégorie de données plutôt que donnée par donnée pour des raisons de réalisme opérationnel.

Niveaux de sensibilité et d'impact

Notion	À retenir
Échelle d'impact	Doit être **homogène** pour toute l'entité. Approche par **impact** plus intuitive pour les métiers que par besoins (disponibilité, intégrité, confidentialité).
Gravité d'impact	**4 niveaux** : **mineur**, **significatif**, **grave** ou **critique**. Évalués selon l'atteinte physique/psychique, perte financière, juridique, opérationnelle et médiatique.
Sensibilité données	**3 niveaux** : **non sensible** (impact mineur), **sensible** (au moins un impact significatif, niv. 2, ou grave, niv. 3), **très sensible** (impact critique, niv. 4 ; ex: **Diffusion Restreinte**, hors régime classifié).

Identification et catégorisation des données

Notion	À retenir
Inventaire macroscopique	Réaliser un inventaire des données et traitements de l'entité, **sans se limiter** aux éléments sensibles.
Catégorisation	Catégoriser par **division/direction** et par **contexte** (utilisation, test, production, contrôle interne). Identifier **source** et **responsable**.
Évaluation sensibilité	Le **RSSI** questionne les besoins métier pour éviter sous-évaluation ou surévaluation. Validation par les **décideurs**. Préférer l'évaluation **par catégorie**.
Agrégation et revues	Élever le niveau si **accumulation/agrégation** (ex: niveau **2** → **3**). Inclure des **revues régulières** (sensibilité évolutive).

Exigences et interconnexions

Notion	À retenir
Exigences par niveau	Identifier les besoins de sécurité (ex: **disponibilité**) liés aux impacts redoutés et appliquer des **mesures ad hoc** (ex: **plan de continuité d'activité**).
Cadrage et priorisation	Cadrer les interconnexions entre niveaux (incluant le **non sensible**). Prioriser selon l'**exposition** (nombre/type d'utilisateurs) et la **maîtrise des interfaces** (physique, logique, réseau tiers).

Pièges et confusions

- ⚠ Confondre les recommandations du guide avec les mesures de sécurisation spécifiques aux informations classifiées Secret ou Très secret.
- ⚠ Penser que le guide couvre le régime des informations classifiées régi par l'IGI 1300.
- ⚠ Évaluer la sensibilité donnée par donnée au lieu de privilégier une évaluation par catégorie.
- ⚠ Oublier que l'agrégation de données peut élever leur niveau de sensibilité.

Sigles et définitions

Données ou traitements sensibles : ceux dont la compromission, la perte ou l'altération peut sérieusement entraver la capacité de l'entité à atteindre ses objectifs, voire à exister

Diffusion Restreinte (DR) : mention désignant les informations très sensibles pouvant avoir un impact critique, sans relever du régime classifié

IGI 1300 : instruction générale interministérielle qui encadre les informations classifiées

Échelle d'impact : outil homogène permettant d'évaluer les conséquences d'une compromission selon des critères humain, financier, juridique, opérationnel et d'image

Auto-test

1. Quels sont les 4 niveaux de gravité d'impact ?
2. Quels sont les 3 niveaux de sensibilité des données ?
3. Que doit faire le RSSI pour éviter la sous-évaluation ou la surévaluation ?
4. Quel type d'inventaire doit être réalisé pour les données et traitements ?
5. Que se passe-t-il pour le niveau de sensibilité en cas d'accumulation ou d'agrégation ?

Réponses : **1.** mineur, significatif, grave ou critique · **2.** non sensible, sensible, très sensible · **3.** questionner les besoins métier · **4.** un inventaire macroscopique · **5.** il s'élève

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.